

visiting a page. An attacker utilized flaws in the coding of the application in order to inject JavaScript code into the web page which can then be used for malicious purposes.



Any part of an application where any input from a URL request is somehow being outputted in the HTML could be vulnerable to such an attack. This kind of attack is of three types, Stored, Reflected and DO-based. We shall cover the first two in detail.

A stored XSS attack relies on vulnerabilities in commenting systems, forums etc where the injected code will persist in a database. For example, in a comment box one might be permitted to post HTML code directly, and while this is rare, such a system could easily be exploited by XSS.

Let us say, one user posts a message which includes some kind of JavaScript element. Since this will posted as a comment, and be part of the webpage, the JavaScript code included will be run on every system which accesses the page with that comment on it.

Since such a script would be running in the context of the end user, it could be used to post personal data about the user to his website.

Let us take an example from the WebGoat. What we have here is a basic messaging system which



We then submit this code to the server, and it shows up in the message list

allows one to post messages which all can read. In our first attack, we will simply create a message which includes a script which displays an alert: `<script>document.location="http://www.maliciouswebsite.com";</script>`

With this script, any user clicking on that link would redirect the